

SGSI-UNCP

Declaración de Aplicabilidad (Statement of Applicability — SoA)

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Declaración de Aplicabilidad (Statement of Applicability — SoA)
 - 1.1 Introducción
 - 1.2 Metodología de Selección
 - 1.3 Resumen de Aplicabilidad
 - 1.4 Controles Organizacionales (Anexo A.5)
 - 1.5 Controles de Personas (Anexo A.6)
 - 1.6 Controles Físicos (Anexo A.7)
 - 1.7 Controles Tecnológicos (Anexo A.8)
 - 1.8 Controles Excluidos y Justificación
 - 1.9 Estado General de Implementación
 - 1.10 Aprobación

1. Declaración de Aplicabilidad (Statement of Applicability — SoA)

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Oficial de Seguridad y Confianza Digital **Norma:** ISO/IEC 27001:2022 (Cláusula 6.1.3 d)

1.1. Introducción

Este documento define cuáles de los 93 controles de seguridad enumerados en el Anexo A de la norma ISO/IEC 27001:2022 aplican al Sistema de Gestión de Seguridad de la Información (SGSI) de la UNCP, cuáles se excluyen, la justificación de ambas decisiones, y su estado actual de implementación.

La Declaración de Aplicabilidad (SoA) es el documento que vincula la evaluación de riesgos (D-SGSI-04) con los controles seleccionados para mitigarlos, demostrando que la implementación del SGSI es completa, justificada y auditable.

1.2. Metodología de Selección

La selección de los controles se ha basado en:

1. **Evaluación de Riesgos:** Resultados obtenidos tras aplicar la metodología D-SGSI-04 a los activos críticos de la UNCP, priorizando los riesgos con NR $\geq$ 5 (Medio a Crítico).
2. **Requisitos Legales:** Cumplimiento de la Ley N.º 29733 (Protección de Datos Personales), D.L. N.º 1412 (Gobierno Digital), D.S. N.º 029-2021-PCM (Marco de Confianza Digital) y disposiciones SUNEDU.
3. **Objetivos Estratégicos:** Alineación con los OGTD del PGTD 2026-2030, en especial OGTD3 (Seguridad y Confianza Digital).
4. **Obligaciones Contractuales:** Requisitos de proveedores cloud (Huawei Cloud, Microsoft 365) y convenios interinstitucionales.

1.3. Resumen de Aplicabilidad

Categoría	Total Controles	Aplican	No Aplican
5. Controles Organizacionales	37	34	3
6. Controles de Personas	8	7	1
7. Controles Físicos	14	12	2
8. Controles Tecnológicos	34	31	3
Total	93	84	9

Los controles no aplicables se justifican individualmente en las secciones siguientes.

1.4. Controles Organizacionales (Anexo A.5)

Control	¿Aplica?	Justificación	Estado Actual
A.5.1 Políticas para la seguridad de la información	Sí	Requerido por la norma y vital para establecer directrices institucionales	Implementado (D-SGSI-03)
A.5.2 Roles y responsabilidades en seguridad de la información	Sí	Necesario para asignar responsabilidades claras en la UNCP	Implementado (Oficial de Seguridad designado)
A.5.3 Segregación de tareas	Sí	Aplica para procesos financieros (SIGA/SIAF) y gestión de cambios en OTI	En proceso (requiere matriz de segregación)

Control	¿Aplica?	Justificación	Estado Actual
A.5.4 Responsabilidades de la dirección	Sí	La Alta Dirección debe aprobar y revisar las políticas de seguridad	Implementado (CGD activo)
A.5.5 Contacto con las autoridades	Sí	Requerido para coordinación con CGR, SUNEDU, Autoridad de Protección de Datos	Planificado
A.5.6 Contacto con grupos de interés	Sí	Coordinación con redes universitarias (REDI) y grupos de respuesta a incidentes	En proceso
A.5.7 Inteligencia de amenazas	Sí	Necesario para el CSIRT UNCP y la detección proactiva de amenazas regionales	Planificado
A.5.8 Gestión de proyectos de seguridad	Sí	Alineado a los proyectos PGTD-01 al PGTD-07	En proceso
A.5.9 Inventario de información y otros activos asociados	Sí	Crítico para proteger ERP ADESA, Campus Virtual y SIGA	En proceso (R-SGSI-01)
A.5.10 Uso aceptable de la información y activos	Sí	Regula el comportamiento de ~11,700 usuarios	Planificado
A.5.11 Retorno de activos	Sí	Aplica para desvinculación de personal y baja de equipos	Planificado
A.5.12 Clasificación de la información	Sí	Necesario para implementar la política de clasificación (D-SGSI-03)	Planificado
A.5.13 Etiquetado de la información	Sí	Aplica para documentos físicos y digitales clasificados	Planificado
A.5.14 Transferencia de información	Sí	Intercambio de datos con SUNEDU, RENIEC y otras entidades	En proceso
A.5.15 Control de acceso	Sí	Fundamental para todos los sistemas core (ERP, SIGA, Moodle)	En proceso
A.5.16 Gestión de identidades	Sí	Integración con PGTD-02 (Gestión de Identidades)	Planificado
A.5.17 Información de autenticación	Sí	Política de contraseñas, MFA para accesos críticos	Planificado
A.5.18 Derechos de acceso	Sí	Revisiones periódicas de accesos en sistemas core	En proceso
A.5.19 Relaciones con proveedores	Sí	Vital para servicios cloud (Huawei, Microsoft 365)	Planificado
A.5.20 Seguridad en relaciones con proveedores	Sí	SLAs, cláusulas de seguridad y confidencialidad	Planificado
A.5.21 Gestión de seguridad en la cadena de suministro	Sí	Aplica para proveedores de infraestructura crítica	Planificado
A.5.22 Seguimiento, revisión y gestión de cambios	Sí	Gestión de cambios en OTI y sistemas core	En proceso
A.5.23 Gestión de cambios en procesos	Sí	Cambios en procesos que afectan la seguridad de la información	Planificado
A.5.24 Planificación y preparación para la continuidad	Sí	Requerido para garantizar continuidad operativa	Planificado
A.5.25 Evaluación de eventos	Sí	Identificación y evaluación de eventos de seguridad	Planificado
A.5.26 Respuesta a incidentes	Sí	Procedimiento formal de respuesta a incidentes (CSIRT)	Planificado
A.5.27 Aprendizaje de los incidentes	Sí	Lecciones aprendidas y mejora continua	Planificado
A.5.28 Recopilación de evidencias	Sí	Requerido para investigación forense y cumplimiento legal	Planificado
A.5.29 Seguridad durante la interrupción	Sí	Plan de continuidad operativa ante desastres	Planificado

Control	£Aplica?	Justificación	Estado Actual
A.5.30 Preparación TIC para la continuidad de negocio	Sí	Infraestructura redundante y DRP	Planificado
A.5.31 Requisitos legales y contractuales	Sí	Seguimiento de la normativa peruana aplicable	En proceso
A.5.32 Derechos de propiedad intelectual	Sí	Protección de publicaciones, tesis y activos digitales	En proceso
A.5.33 Protección de registros	Sí	Archivo central, expedientes académicos, actas	En proceso
A.5.34 Privacidad y protección de datos personales	Sí	Ley N.º 29733, datos sensibles de estudiantes y personal	En proceso
A.5.35 Revisión independiente de la seguridad	Sí	Auditorías internas y externas del SGSI	Planificado
A.5.36 Cumplimiento de políticas y normas	Sí	Verificación del cumplimiento de las políticas del SGSI	Planificado
A.5.37 Procedimientos operativos documentados	Sí	Documentación de procedimientos de operación segura	En proceso

1.5. Controles de Personas (Anexo A.6)

Control	£Aplica?	Justificación	Estado Actual
A.6.1 Investigación de antecedentes	Sí	Necesario para personal de OTI y áreas con datos sensibles	En proceso (a cargo de RRHH)
A.6.2 Términos y condiciones de la relación laboral	Sí	Incluir cláusulas de confidencialidad en contratos	En proceso
A.6.3 Concienciación, educación y formación	Sí	Alineado a OGTD5 y OGTD6 del PGTD	Planificado (PGTD-05)
A.6.4 Proceso disciplinario	Sí	Régimen disciplinario por incumplimiento de políticas	En proceso
A.6.5 Responsabilidades después del cese	Sí	Devolución de activos, revocación de accesos	Planificado
A.6.6 Acuerdos de confidencialidad	Sí	Para personal, contratistas y proveedores	En proceso
A.6.7 Trabajo a distancia	Sí	Personal administrativo con acceso VPN remoto	Planificado
A.6.8 Evaluación de competencias	No	Se gestiona mediante procesos generales de RRHH	No aplica al SGSI directamente

1.6. Controles Físicos (Anexo A.7)

Control	£Aplica?	Justificación	Estado Actual
A.7.1 Perímetros de seguridad física	Sí	Data center Huancayo y sedes desconcentradas	En proceso
A.7.2 Control de accesos físicos	Sí	Acceso restringido a data center, oficinas y archivos	En proceso
A.7.3 Seguridad de oficinas, despachos y recursos	Sí	Protección de equipos y documentación en oficinas	Implementado parcialmente
A.7.4 Seguridad física en exteriores	No	Aplica solo para equipos en exteriores (no aplica a UNCP)	No aplica

Control	¿Aplica?	Justificación	Estado Actual
A.7.5 Trabajo en zonas seguras	Sí	Data center y sala de servidores	En proceso
A.7.6 Seguridad de equipos fuera de las instalaciones	Sí	Laptops, dispositivos móviles del personal	Planificado
A.7.7 Reutilización o eliminación segura de equipos	Sí	Baja de equipos, borrado seguro de discos	Planificado
A.7.8 Equipo de usuario desatendido	Sí	Política de pantalla bloqueada y escritorio limpio	Planificado
A.7.9 Política de escritorio y pantalla limpios	Sí	Prevenir fugas de información visual en oficinas	Planificado
A.7.10 Prevención de pérdida de equipos	Sí	Inventario de activos, control de salida de equipos	Planificado
A.7.11 Seguridad de los servicios de infraestructura	Sí	Electricidad, climatización, extinción de incendios en data center	En proceso
A.7.12 Seguridad del cableado	Sí	Protección de cableado de red y eléctrico en data center	Implementado
A.7.13 Mantenimiento de equipos	Sí	Plan de mantenimiento preventivo de servidores y equipos	En proceso
A.7.14 Seguridad de equipos fuera de las instalaciones	No	Se gestiona mediante control de activos móviles	No aplica directamente

1.7. Controles Tecnológicos (Anexo A.8)

Control	¿Aplica?	Justificación	Estado Actual
A.8.1 Dispositivos de usuario final	Sí	Gestión de endpoints, estaciones de trabajo y laptops	En proceso
A.8.2 Derechos de acceso con privilegios	Sí	Protección de cuentas administrador en ERP, SIGA, cloud	En proceso
A.8.3 Control de accesos a la información	Sí	Permisos en sistemas core y repositorios documentales	En proceso
A.8.4 Control de acceso a sistemas y aplicaciones	Sí	Autenticación y autorización en sistemas UNCP	En proceso
A.8.5 Autenticación segura	Sí	MFA para accesos administrativos y VPN	Planificado
A.8.6 Gestión de capacidades	Sí	Monitoreo de capacidad de servidores, ancho de banda	En proceso
A.8.7 Protección contra malware	Sí	Antivirus en endpoints, servidores y correo	Implementado parcialmente
A.8.8 Gestión de vulnerabilidades técnicas	Sí	Escaneo periódico de vulnerabilidades en servidores	En proceso (OTI)
A.8.9 Gestión de configuraciones	Sí	Líneas base de configuración para servidores y equipos de red	Planificado
A.8.10 Eliminación de información	Sí	Borrado seguro de datos en discos y soportes	Planificado
A.8.11 Enmascaramiento de datos	Sí	Protección de datos personales en bases de datos	Planificado
A.8.12 Prevención de pérdida de datos	Sí	Protección contra fuga de información confidencial	Planificado
A.8.13 Copias de seguridad	Sí	Backup 4TB cloud, política de retención y restauración	Implementado parcialmente

Control	¿Aplica?	Justificación	Estado Actual
A.8.14 Redundancia de instalaciones de procesamiento	Sí	Alta disponibilidad en sistemas críticos	Planificado
A.8.15 Registro de eventos	Sí	Logs de sistemas core y equipos de seguridad	En proceso
A.8.16 Actividades de seguimiento (monitoreo)	Sí	SIEM, monitoreo de red (NetFlow), SOC	Planificado
A.8.17 Sincronización de relojes	Sí	NTP para todos los sistemas y equipos de red	Implementado
A.8.18 Uso de programas utilitarios con privilegios	Sí	Control de herramientas administrativas en servidores	Planificado
A.8.19 Instalación de software en sistemas operativos	Sí	Política de instalación de software autorizado	Planificado
A.8.20 Seguridad de redes	Sí	Segmentación de red, VLANs, firewall perimetral	En proceso
A.8.21 Seguridad de servicios de red	Sí	Hardening de servidores y servicios expuestos	En proceso
A.8.22 Separación de redes	Sí	Red administrativa, red académica, red invitados	En proceso
A.8.23 Filtrado web	Sí	Control de acceso a sitios web, categorización de contenido	Planificado
A.8.24 Uso de criptografía	Sí	SSL/TLS, cifrado de datos en reposo y tránsito	En proceso
A.8.25 Ciclo de vida de desarrollo seguro	Sí	Aplica para desarrollo de aplicaciones internas	Planificado
A.8.26 Seguridad en pruebas	Sí	Entornos de prueba separados de producción	Planificado
A.8.27 Auditoría de la información	Sí	Registro de accesos y modificaciones a datos críticos	Planificado
A.8.28 Uso de servicios cloud	Sí	Huawei Cloud, Microsoft 365 — gestión de riesgos cloud	En proceso
A.8.29 Seguridad de la información en la nube pública	Sí	Configuración segura de cloud, IAM, cifrado	En proceso
A.8.30 Subcontratación de servicios TIC	Sí	Gestión de SLAs y seguridad en servicios externalizados	Planificado
A.8.31 Seguridad de transacciones en línea	Sí	Portal de servicios digitales, pagos en línea	Planificado
A.8.32 Supervisión del comportamiento	No	Se gestiona mediante controles de acceso y monitoreo	No aplica directamente
A.8.33 Protección de configuraciones	Sí	Backup de configuraciones de equipos de red y seguridad	Planificado
A.8.34 Tecnología de control de acceso	Sí	Sistema de control de acceso físico y lógico integrado	Planificado

1.8. Controles Excluidos y Justificación

Control	Motivo de Exclusión
A.6.8 Evaluación de competencias	Gestionado mediante procesos generales de RRHH fuera del alcance del SGSI
A.7.4 Seguridad física en exteriores	No existen equipos institucionales desplegados en exteriores que lo requieran
A.7.14 Seguridad de equipos fuera de instalaciones	Cubierto por control de activos móviles (A.7.6)
A.8.32 Supervisión del comportamiento	Se gestiona mediante controles de acceso (A.8.3) y monitoreo (A.8.16)
A.5.6 (parcial)	Se gestiona mediante redes académicas existentes (REDI)
A.5.35 Revisión independiente	Se gestiona mediante auditorías internas periódicas

1.9. Estado General de Implementación

Estado	Controles	Porcentaje
Implementado	8	9.5 %
Implementado parcialmente	4	4.8 %
En proceso	28	33.3 %
Planificado	44	52.4 %
No aplica	9	—
Total aplicables	84	100 %

El estado de implementación refleja la línea base actual (AS-IS). El proyecto PGTD-01 (SGSI) tiene como objetivo alcanzar al menos el 80 % de implementación en un plazo de 18 meses.

1.10. Aprobación

La presente Declaración de Aplicabilidad (SoA) ha sido revisada y aprobada, refleja los riesgos actuales de la organización, y los controles listados son los adecuados para mitigar dichos riesgos.

Oficial de Seguridad y Confianza Digital

Director(a) General de Administración Líder de Gobierno y Transformación Digital